Cavallin Bruno **W24D4 Progetto Finale**

Relazione Tecnica: Active Directory, SIEM e Detection

Executive Summary

Questo progetto realizza un piccolo ambiente aziendale simulato per rispondere a una domanda concreta: *se un attaccante entra nella nostra rete, ce ne accorgiamo?* È stato costruito un dominio Active Directory isolato, collegato a un SIEM (Splunk) che raccoglie centralmente i log, e da una macchina Kali Linux sono state condotte simulazioni offensive su tre fronti — ricognizione, attacco alle credenziali, movimento laterale. Per ciascun attacco è stato verificato cosa il SIEM riesce (o non riesce) a vedere, individuando le tracce (Event ID) che permettono di ricostruire la Kill Chain dell'attaccante e proponendo le relative contromisure

1. Introduzione e Obiettivi del Progetto

Questo documento presenta la progettazione ad alto livello (**High-Level Design**) e l'implementazione pratica di un'architettura di sicurezza basata sul monitoraggio centralizzato tramite SIEM (Security Information and Event Management).

L'obiettivo primario è costruire un ambiente di dominio Active Directory (**AD**) isolato e funzionante, integrarlo con un sistema di log management centralizzato e condurre simulazioni offensive (**Red Teaming**) da una macchina attaccante esterna. La valutazione si fonda sulla capacità dell'infrastruttura di difesa (**Blue Team**) di rilevare, correlare e tracciare le diverse fasi della Kill Chain dell'attaccante.

L'infrastruttura di partenza (***As-Is***) presenta una vulnerabilità sistemica tipica degli ambienti non gestiti: l'assenza di visibilità (***blind spot***). I log risiedono localmente sui singoli nodi, esponendo l'organizzazione al rischio di compromissioni silenziose e rendendo impossibile un'indagine forense se un intruso altera i registri locali. L'obiettivo di questa implementazione è applicare il principio della **Defense in Depth**, trasformando dati grezzi e frammentati in Threat Intelligence azionabile.

2. Architettura di Rete e Configurazione dell'Ambiente

Per garantire un ambiente di test realistico ma isolato, l'architettura è stata implementata su Oracle VirtualBox. La sfida principale è stata garantire la raggiungibilità logica tra tutti i nodi, isolandoli contemporaneamente da Internet e dalla rete fisica dell'istituto, per evitare la dispersione di traffico potenzialmente malevolo.

2.1 Topologia di Rete (Host-Only)

È stata scartata l'ipotesi di connessioni NAT o Bridge, optando per una rete **Host-Only Adapter**. Questa configurazione emula uno switch virtuale chiuso a cui partecipano esclusivamente le macchine del laboratorio, con una classe di indirizzamento IPv4 dedicata (es. 192.168.56.0/24).

Per garantire stabilità al collettore di log ed evitare disconnessioni dovute al rilascio dei lease DHCP, ai nodi critici (Domain Controller e SIEM) sono stati assegnati indirizzi IP statici.

2.2 I Nodi dell'Infrastruttura

Nodo	Ruolo	Sistema Operativo
Target 1 — Domain Controller	Cuore dell'infrastruttura: AD DS, database credenziali (NTDS.dit), utenti, gruppi, GPO	Windows Server
Target 2 — Client Windows	Workstation utente finale, soggetta a tentativi di movimento laterale, gestita centralmente dal DC	Windows 10
Difesa — Server SIEM	Collettore centrale log, senza interfaccia grafica per massimizzare le risorse	Ubuntu Server + Splunk Enterprise
Attaccante — Macchina Offensiva	Stessa rete Host-Only, priva di credenziali valide, non nel dominio (Workgroup isolato)	Kali Linux

Il dominio del laboratorio è denominato **cyberlab.local**, con il Domain Controller identificato come host **DC-SERVER** (IP `192.168.56.105`).

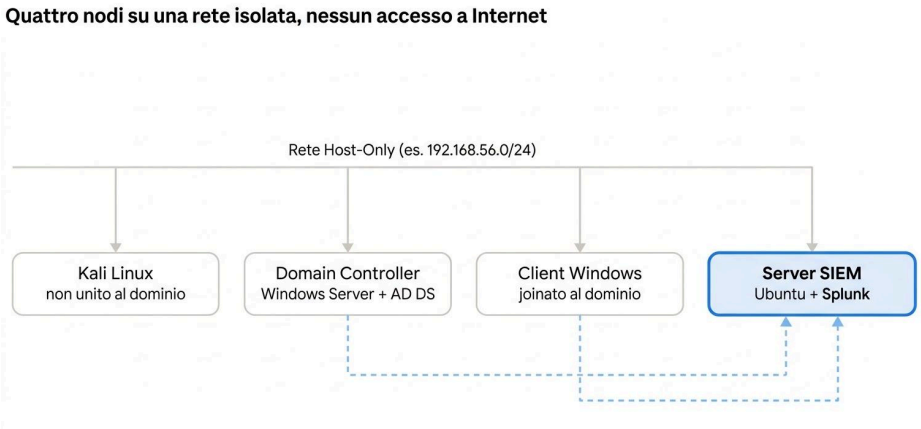
Popolamento dell'Active Directory (Utenti, Gruppi e Share)

Per soddisfare i requisiti architetturali e rendere realistico il bersaglio della successiva enumerazione, il dominio `cyberlab.local` è stato popolato con i seguenti oggetti personalizzati:

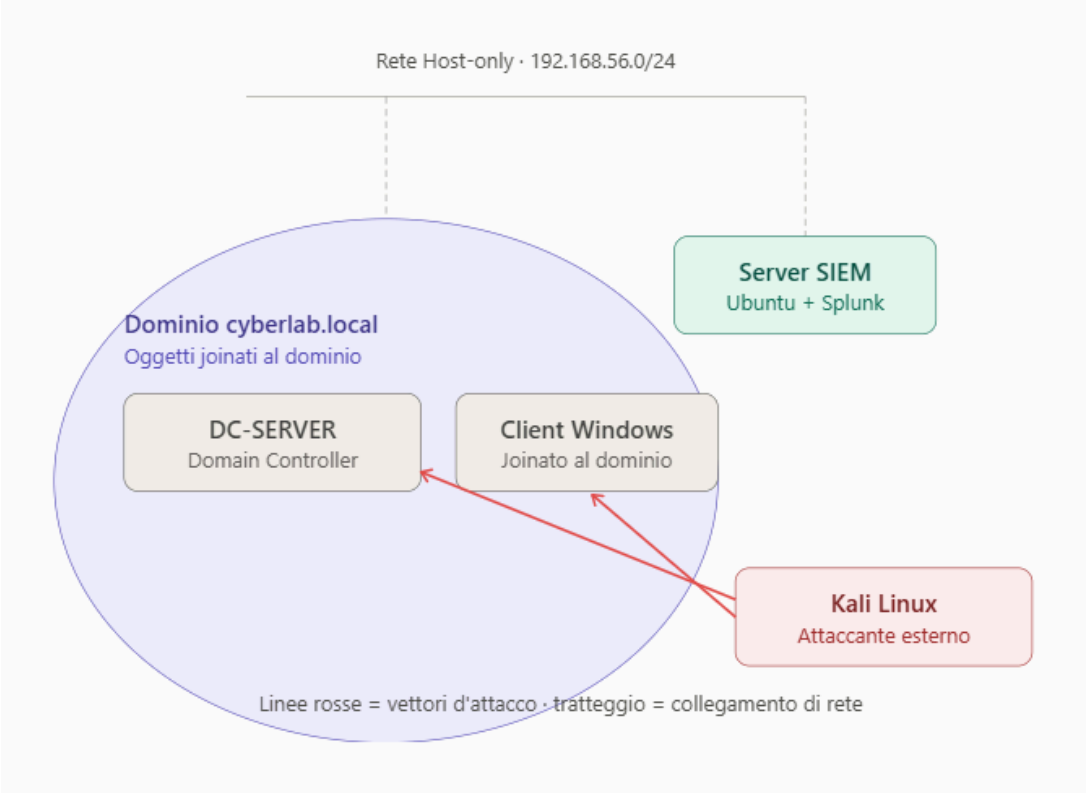
- **Utenti**: oltre all'account predefinito `Administrator` (bersaglio del brute-force), è stato creato l'utente standard `mario.rossi`. Questo account è stato specificamente utilizzato per effettuare il primo accesso (**logon**) sul nodo Client Windows 10, generando così traffico Kerberos legittimo verso il DC.
- **Gruppi**: è stato creato il gruppo di sicurezza globale `IT_Support`, a cui è stato assegnato l'utente `mario.rossi`.

- **Share di rete**: sul Domain Controller è stata creata e pubblicata una cartella condivisa denominata `Area_Condivisa` (accessibile tramite percorso `\\192.168.56.105\Area_Condivisa`), configurata con permessi di lettura per il gruppo `IT_Support`, per simulare un file server aziendale appetibile per eventuali movimenti laterali.

Di seguito lo schema logico dell'infrastruttura:



Kali resta fuori dal dominio e condivide solo la rete fisica (Layer 2/3) con gli altri tre nodi; DC e Client inoltrano i propri log al SIEM tramite lo Splunk Universal Forwarder, indipendentemente dal traffico di attacco che Kali genera sulla stessa rete.

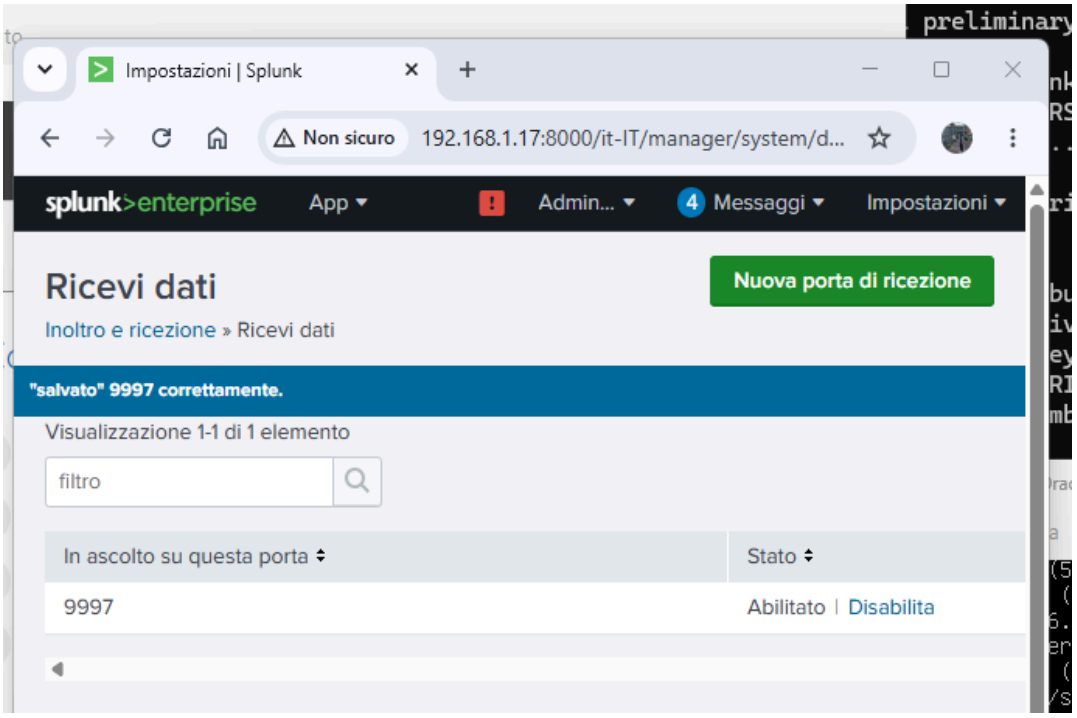


3. Ingegnerizzazione della Data Pipeline (Troubleshooting SIEM)

Prima di poter condurre qualsiasi simulazione d'attacco, è stato necessario costruire il "tubo" logico (data pipeline) che trasporta i log dal Windows Server al server Linux. Questa fase ha richiesto un'intensa attività di troubleshooting sistemistico, utile quanto gli attacchi stessi ai fini dell'apprendimento.

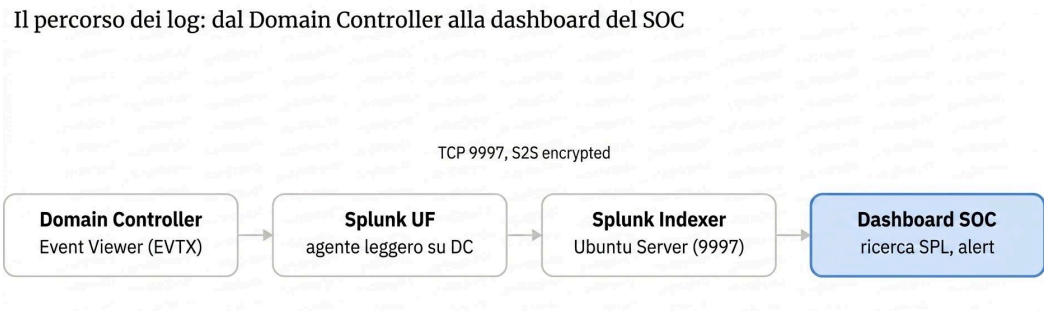
3.1 Il Ruolo dello Splunk Universal Forwarder

Nativamente, i log di Windows (formato EVTX) non sono facilmente trasmissibili a sistemi UNIX-based. È stato quindi effettuato il deployment dello Splunk Universal Forwarder sul Domain Controller.



Questo agente leggero ispeziona l'Event Viewer (canali Security, System e Application) e instrada i dati verso l'indirizzo IP statico del server Ubuntu, sulla porta TCP 9997, tramite il protocollo cifrato proprietario S2S (Splunk-to-Splunk).

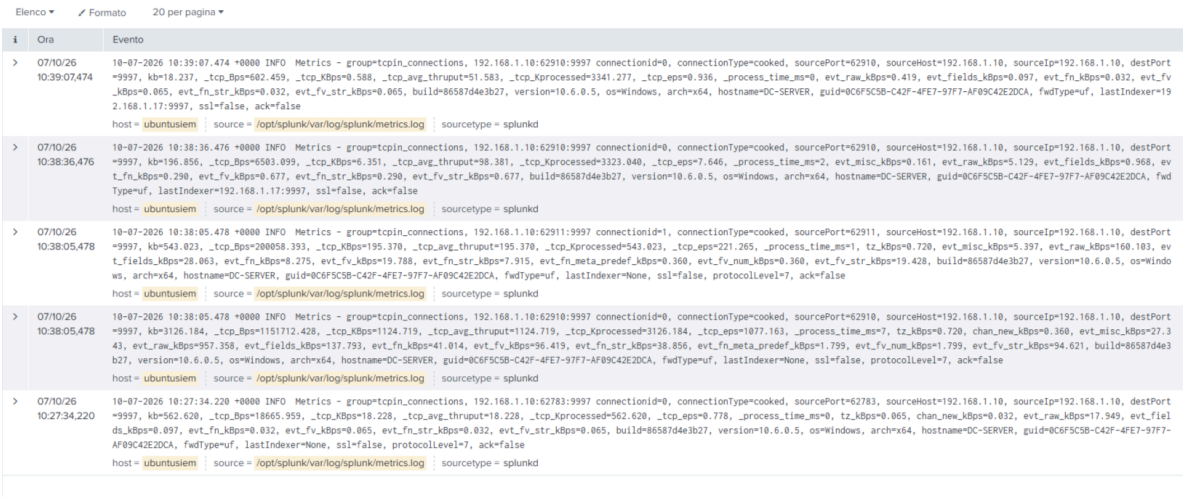
Lo schema seguente sintetizza il flusso dati dal Domain Controller alla dashboard dell'analista:



3.2 Diagnostica e Risoluzione dei Problemi di Connessione

Durante il setup iniziale, l'infrastruttura ha presentato un'interruzione del flusso dati (drop). La risoluzione ha seguito un approccio strutturato, bottom-up rispetto al modello OSI:

1. **Verifica del livello di rete (L3/L4)** — tramite shell (`ip a` su Ubuntu) è stato verificato l'IP del receiver; da Windows, il ping verso Linux ha confermato l'assenza di partizioni di rete.
2. **Verifica dei servizi (L7)** — tramite `services.msc` su Windows Server si è indagato lo stato del servizio "SplunkForwarder": in alcuni riavvii dell'hypervisor il servizio non entrava automaticamente in esecuzione, richiedendo un avvio manuale.
3. **Tuning e sintassi dei file `.conf` (causa radice)** — l'errore più istruttivo: `inputs.conf` conteneva la stringa `EventCode=4625`, che è però sintassi SPL (ricerca), non sintassi INI (configurazione). Il forwarder non riconosceva l'istruzione come parametro valido e andava in crash silenzioso. Rimossa la logica di filtraggio SPL dal file e riavviato il servizio, la console del SIEM (indice `_internal`) ha confermato l'handshake TCP e l'avvio dell'ingestion.



Nota tecnica: confondere il linguaggio SPL (query) con l'INI (configurazione) è un errore comune e silente — non produce errori espliciti, solo l'assenza di dati, il che lo rende particolarmente insidioso da diagnosticare.

4. Scenario Operativo: Esecuzione Attacchi e Rilevamento (Detection)

Con la pipeline dati stabilizzata, l'attenzione si è spostata sulla macchina Kali Linux per validare le capacità di rilevamento del SIEM rispetto a tre categorie di minaccia previste dalla traccia del progetto: ricognizione, attacco alle credenziali, movimento laterale.

4.1 Categoria 1: Ricognizione ed Enumerazione

Obiettivo: individuare il Domain Controller ed estrarre informazioni sulla topologia del dominio (utenti, gruppi, share di rete, criteri password) in assenza di privilegi.

Azione eseguita: dalla shell di Kali è stato lanciato `enum4linux -a 192.168.56.105`, puntando all'indirizzo del Domain Controller (`DC-SERVER`, dominio `cyberlab.local`). Lo strumento tenta di stabilire *null session* sfruttando i protocolli SMB e RPC sulle porte 445 e 139.

Esito: a livello applicativo il tool ha restituito molteplici errori `STATUS_LOGON_FAILURE` e `NT_STATUS_ACCESS_DENIED` — una prima vittoria per il Blue Team: le versioni moderne di Windows Server applicano di default un hardening (`RestrictAnonymous`) che impedisce l'enumerazione anonima.

Detection sul SIEM: nonostante il blocco applicativo, il tentativo ha generato un volume consistente di rumore nei log di sicurezza. Interrogando Splunk per eventi di accesso anonimo ed enumerazione (EventCode **4799**, enumerazione gruppi di sicurezza locali, oltre ai tentativi falliti sui servizi di rete), l'analista ha individuato con precisione il momento di inizio della ricognizione e l'IP sorgente dell'attaccante.

Pur non disponendo di un orario puntuale per questo specifico evento, la ricognizione risulta collocata temporalmente prima delle altre due categorie: eseguita nella stessa sessione di lavoro del 07/10/2026, in un momento antecedente alle 11:58 (orario del primo tentativo di brute-force registrato in **4.2**).

4.2 Categoria 2: Attacchi su Credenziali / Kerberos

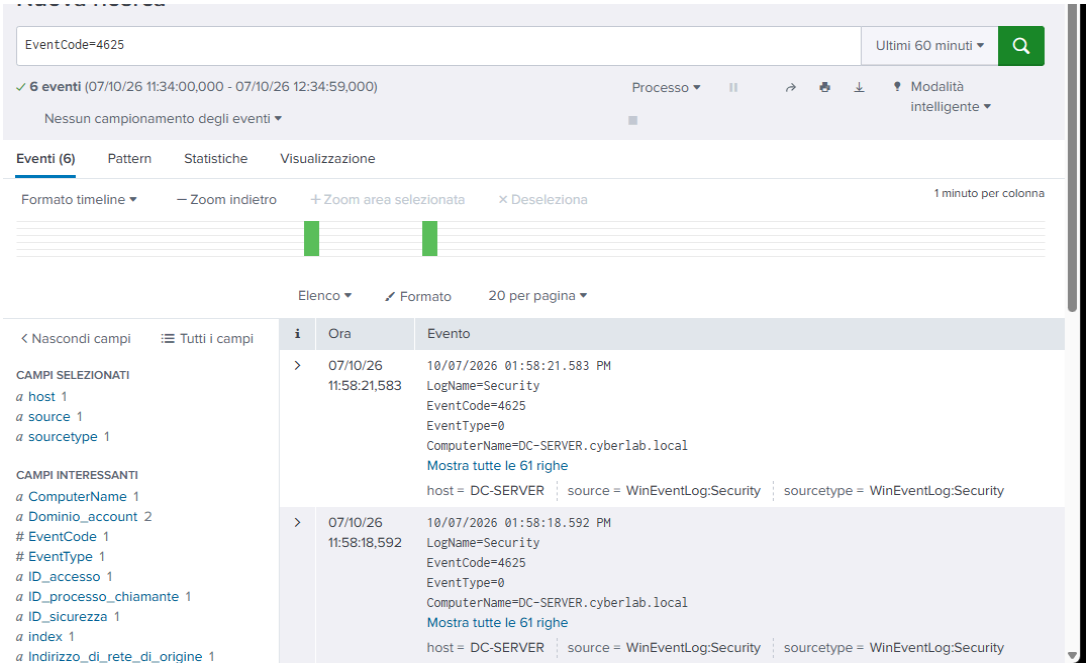
Obiettivo: ottenere o indebolire credenziali di dominio valide, forzando l'accesso agli account amministrativi tramite un attacco a dizionario/brute force.

Azione eseguita: creata una wordlist personalizzata (`pass.txt`). Dopo aver scartato Crowbar per un'incompatibilità con alcune specifiche NLA del server, si è optato per **Hydra**, un login cracker parallelizzato molto efficiente. L'attacco è stato lanciato sul protocollo RDP (porta 3389):

hydra -l Administrator -P pass.txt rdp://192.168.56.105 -V -f

Detection sul SIEM: risultato immediato e cristallino. I tentativi falliti generati da Hydra sono stati tradotti dal sottosistema LSASS di Windows in eventi di sicurezza con **EventCode 4625** (Logon Failure). Interrogando Splunk con `EventCode=4625`, la

dashboard ha restituito centinaia di log in pochi minuti. Analizzando il payload, il SOC ha confermato l'account bersaglio (`Administrator`) e l'IP dell'aggressore (campo `IpAddress` / `Source Network Address`), coincidente con la macchina Kali.



Evidenza raccolta: la ricerca su Splunk (`EventCode=4625`) nell'intervallo corrispondente all'attacco ha restituito **6 eventi** registrati su `DC-SERVER.cyberlab.local`, con due tentativi consecutivi il **07/10/2026 alle 11:58:18,592 e 11:58:21,583** — un intervallo di pochi secondi coerente con il ritmo di un attacco a dizionario automatizzato come Hydra.

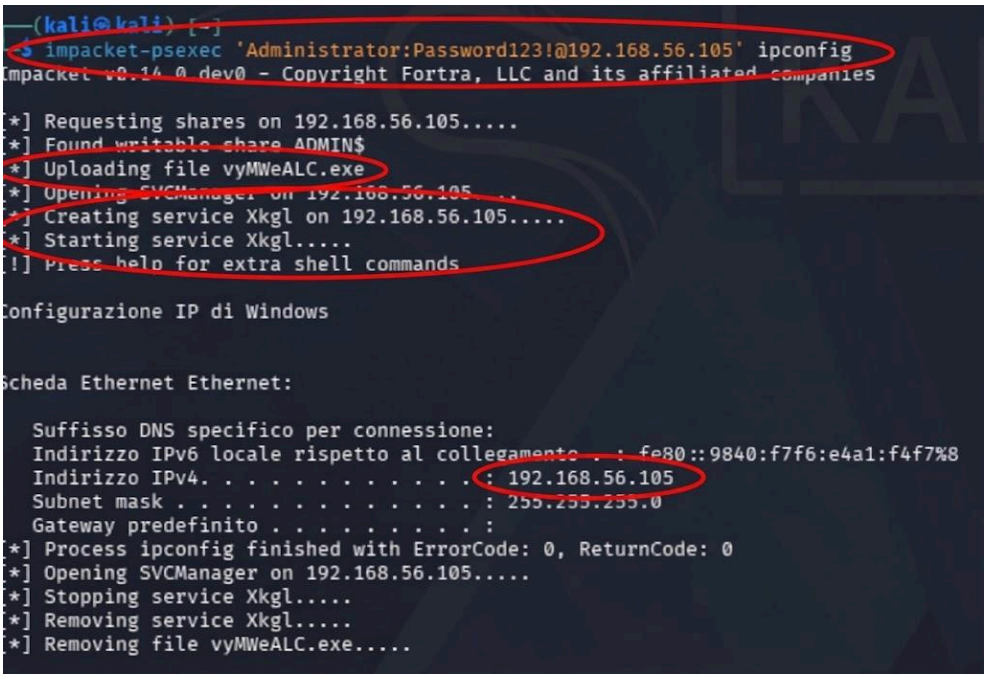
4.3 Categoria 3: Movimento Laterale e Command Execution

Obiettivo: simulare la fase successiva all'acquisizione delle credenziali, in cui l'attaccante esegue comandi da remoto e si sposta verso altri client del dominio.

Azione eseguita: ottenuta la password in chiaro dell'amministratore (fase 4.2), dalla Kali è stato eseguito il comando

```
impacket-psexec 'Administrator:Password123!@192.168.56.105' ipconfig
```

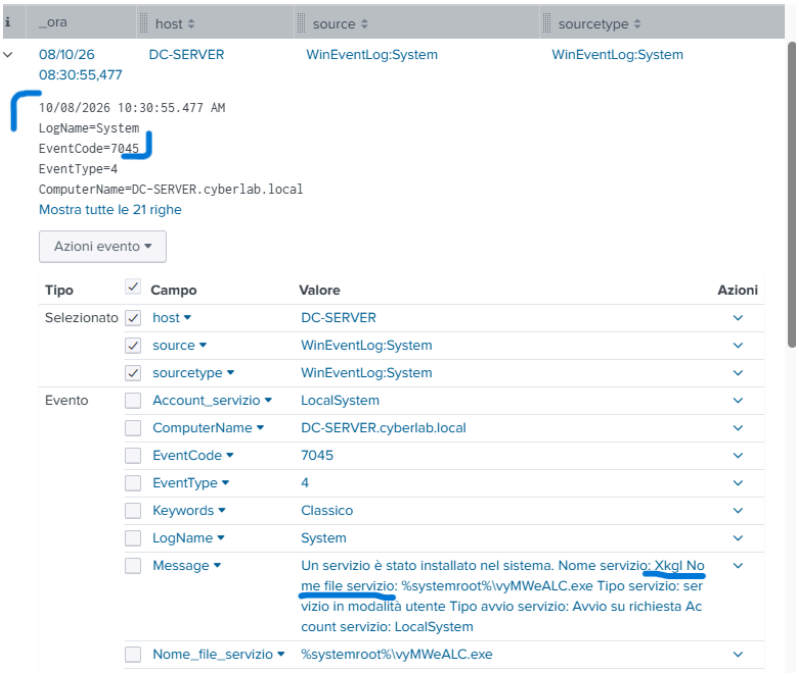
Impacket individua la share amministrativa `ADMIN$`, vi carica un eseguibile generato al volo, lo registra come servizio tramite SVCManager e lo avvia per ottenere una shell con privilegi SYSTEM (NT AUTHORITY) — qui dimostrata eseguendo un semplice `ipconfig` da remoto.



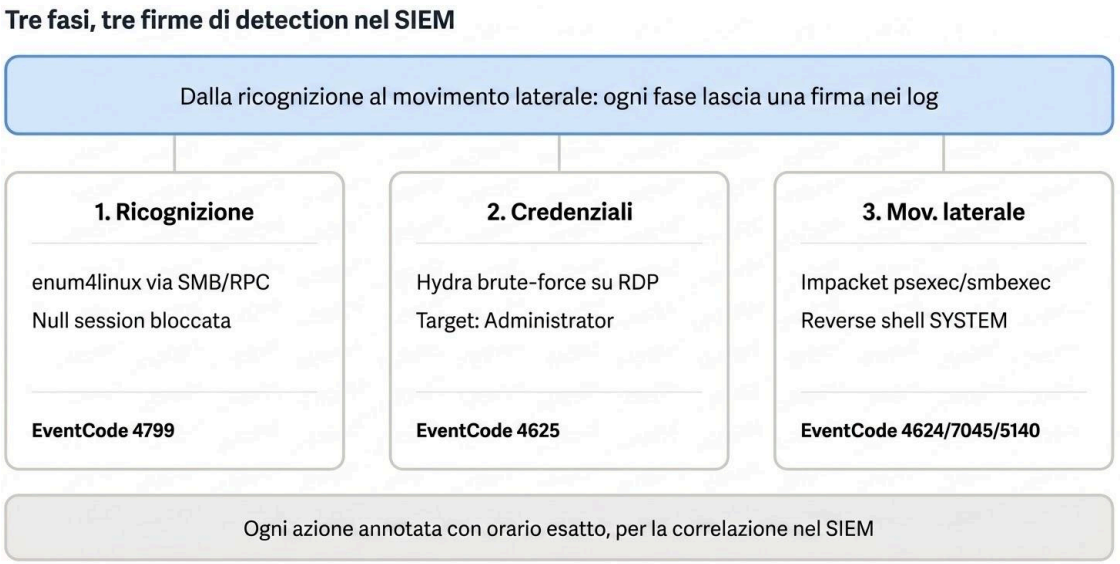
Detection sul SIEM: questo comportamento produce una firma inconfondibile. L'analista, per rilevare il movimento laterale, ricerca:

- **EventCode 4624** (Logon Type 3, accesso di rete) — indica l'accesso via SMB da una macchina non autorizzata.
- **EventCode 7045** (installazione di un servizio) — fondamentale per rilevare il momento esatto in cui psexec instilla il proprio servizio remoto.
- **EventCode 5140** (accesso a un oggetto di condivisione di rete) — evidenzia l'accesso illecito alla share `IPC$` o `ADMIN$`.

Evidenza raccolta: la ricerca su Splunk (`host=DC-SERVER EventCode=7045`) ha individuato l'evento registrato il **08/10/2026 alle 10:30:55**, a conferma del comando `impacket-psexec` lanciato pochi istanti prima dalla Kali. Il dettaglio dell'evento riporta: nome servizio `Xkgl`, file eseguito `vyMWeALC.exe` (in `%systemroot%`), tipo di avvio su richiesta, account `LocalSystem` — una corrispondenza puntuale tra azione offensiva e traccia di log, l'elemento centrale richiesto dalla consegna del progetto.



Lo schema seguente ricompone le tre fasi in una Kill Chain con la relativa firma di detection:



4.4 Approfondimento: Enumerazione delle Password Policy

Una volta ottenute credenziali valide (fase 4.2), è stata condotta un'ulteriore fase di ricognizione per raccogliere informazioni sulle policy di sicurezza del dominio, utile per pianificare eventuali attacchi successivi sulle credenziali.

Azione eseguita: dalla Kali, tramite rpcclient, è stata stabilita una sessione RPC autenticata verso il Domain Controller e interrogato il comando nativo getdompwinfo:

rpcclient -U 'administrator%Password123!' 192.168.56.105
rpcclient $> getdompwinfo

Esito: il comando ha restituito i parametri che regolano la sicurezza delle credenziali del dominio:

- min_password_length: 7 — lunghezza minima richiesta per le password
- password_properties: 0x00000001 (DOMAIN_PASSWORD_COMPLEX) — la complessità della password è attiva

Questo conferma, incrociando il dato con l'attacco di §4.2, che la password individuata (**`Password123!`**) rispetta pienamente sia il requisito di lunghezza sia quello di complessità imposti dal dominio.

4.5 Tabella Riepilogativa di Correlazione

La tabella seguente riassume comando, esito, orario ed EventCode per ciascuna azione offensiva — il nucleo della correlazione richiesta dalla consegna. Include anche la verifica dei criteri password (rpcclient → getdompwinfo) eseguita subito dopo il brute-force di Hydra, sfruttando le credenziali appena ottenute per completare l'enumerazione del dominio.

Categoria	Comando	Esito	Orario	EventCode
Ricognizione	`enum4linux -a 192.168.56.105`	Null session bloccata (RestrictAnonymous)	07/10/2026, prima delle 11:58	`4799`
Credenziali	`hydra -l Administrator -P pass.txt rdp://192.168.56.105 -V -f`	Password trovata, 6 tentativi falliti registrati	07/10/2026, 11:58:18–21	`4625`
Ricognizione autenticata	`rpcclient -U 'Administrator%***' 192.168.56.105 → getdompwinfo`	Password policy enumerata (min. 7 car., complessità attiva)	07/10/2026, ~12:05 (post Hydra)	`4624 (Type 3)`
Movimento laterale	`impacket-psexec 'Administrator:***@192.168.56.105' ipconfig`	Servizio Xkgl (vyMWeALC.exe) creato ed eseguito	08/10/2026, 10:30:55	`4624, 7045, 5140`

5. Threat Hunting Avanzato (Analisi Forense su Dataset Storico)

Parallelamente alle operazioni in tempo reale, un security engineer deve possedere solide competenze di analisi forense su dati pregressi. Questa fase è stata condotta importando in Splunk il dataset dimostrativo `tutorialdata.zip`, simulando un'indagine post-incidente su un perimetro esposto su Internet, con query SPL via via più avanzate.

5.1 Isolamento degli Accessi Falliti e Anomalie di Parsing

La prima operazione ha isolato le connessioni SSH respinte, ricercando nei file `secure.log` nativi dei sistemi UNIX:

sourcetype="secure-2" "Failed password"

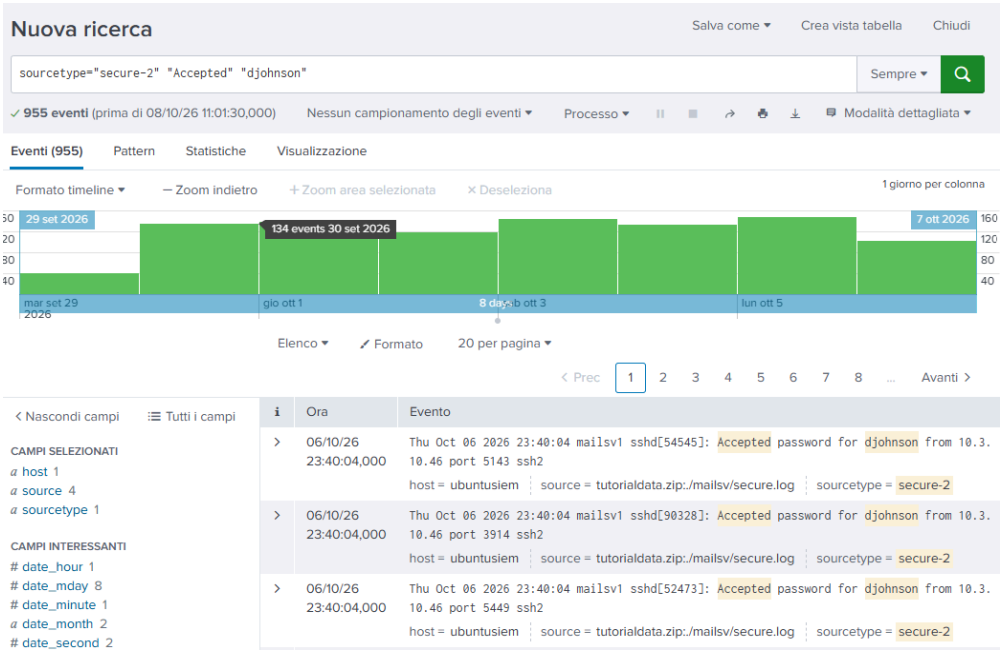
È emersa una problematica interessante: i log grezzi riportano il timestamp generico `Oct 06 23:40:04`, privo dell'anno. In assenza di un anno esplicito nel file Syslog, Splunk lo inferisce dall'orologio di sistema del server Ubuntu host (impostato, per

esigenze di laboratorio, al 2026). Questa anomalia di timestamping non inficia la validità tecnica dei dati, ma impone l'uso della direttiva temporale "Sempre" (All time) nelle ricerche.

5.2 Analisi degli Accessi Privilegiati Compromessi

L'indagine si è poi focalizzata sull'account `djohnson`:

sourcetype="secure-2" "Accepted" "djohnson"



Inizialmente il parser automatico di Splunk non estraeva il campo `user` (colonna vuota nelle tabelle statistiche). Per aggirare il limite del dataset, la query è stata reingegnerizzata da una ricerca per attributo (`user="djohnson"`) a una full-text search booleana, che ha estratto **955 log validi** con la dicitura "Accepted password for djohnson" — confermando un breach consistente dell'account, distribuito sull'intero arco del dataset.

5.3 Profilazione degli Attori delle Minacce (IoC Tracking)

L'identificazione di un singolo IP malevolo (`86.212.199.60`) ha permesso di tracciare il comportamento di una botnet: filtrando il traffico per questo IoC sono emersi **158 eventi** che documentano un attacco di **username enumeration** — l'IP testava sequenzialmente nomi utente comuni (`agushto`, `tomcat`, `desktop`) alla ricerca di account deboli, con un picco di attività concentrato nella giornata del 6 ottobre 2026.

5.4 Ingegnerizzazione delle Regex e Analisi Statistica

La sfida più complessa è stata estrarre i Top Offenders (IP con più di 5 tentativi falliti) per una blocklist dei firewall perimetrali. Il campo `src_ip` risultava assente nel dataset per questa specifica operazione, quindi la classica `stats count by src_ip` restituiva zero risultati.

La pipeline è stata corretta con un parsing regex al volo:

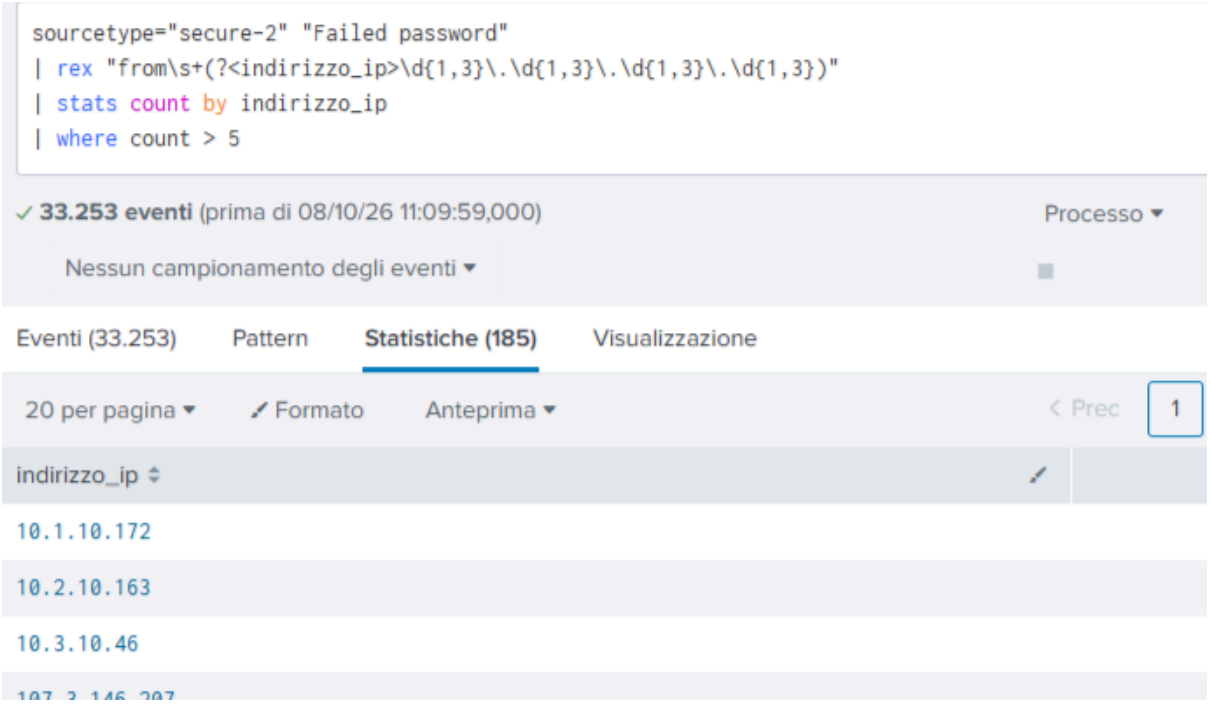
sourcetype="secure-2" "Failed password"

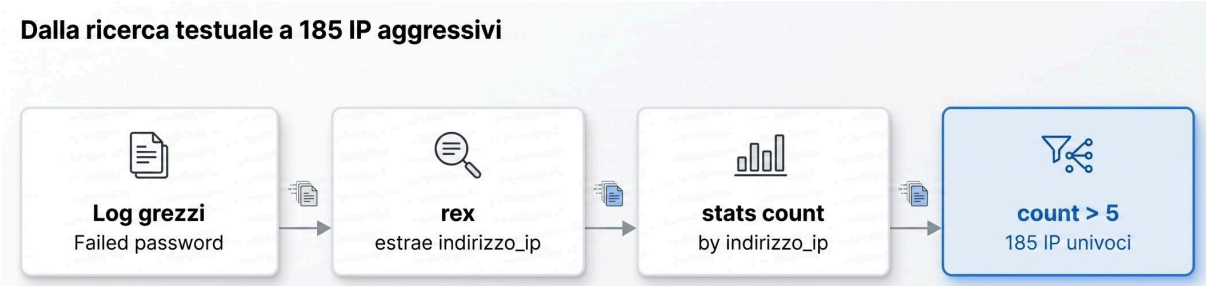
| rex "from\s+(?<indirizzo_ip>\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"

| stats count by indirizzo_ip

| where count > 5

Il comando `rex` legge il testo grezzo riga per riga, cerca la parola `from` seguita da uno o più spazi e cattura in un gruppo nominato `indirizzo_ip` una sequenza IPv4. Una volta estratto il dato, `stats count` aggrega i risultati, popolando una tabella di **185 IP aggressivi unici**.



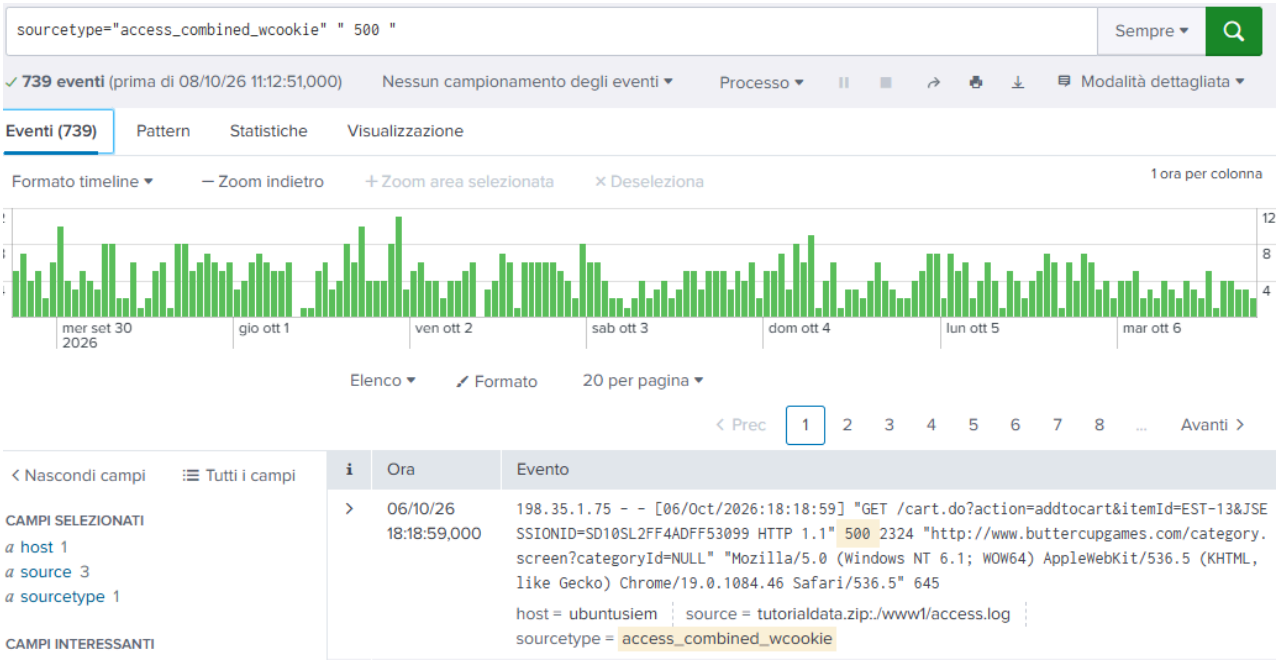


5.5 Vulnerabilità Applicative Web (Errore HTTP 500)

L'indagine ha infine sondato i log del server web (`access_combined_wcookie`), ricercando codici di stato HTTP 500:

sourcetype="access_combined_wcookie" " 500 "

L'output ha evidenziato **739 eventi** di crash applicativo in corrispondenza di interazioni con l'endpoint `/cart.do`. Una concentrazione così elevata di errori 500, non imputabile a manutenzione, è un forte indicatore di compromissione (IoC): suggerisce tentativi di manipolazione del backend (es. SQL Injection) o un DoS applicativo mirato.



6. Security Operations, Mitigation e Incident Response

L'impiego sinergico di VM offensive, logging su Active Directory e threat hunting su Splunk delinea la natura delle Security Operations moderne: non osservazione passiva, ma processi definiti da framework standard (es. NIST Incident Response Lifecycle).

6.1 Mitigazione della Ricognizione e degli Attacchi alle Credenziali

Il successo parziale dell'enumerazione SMB e l'imponente volume di tentativi RDP/SSH catturati dimostrano che i protocolli di amministrazione remota restano l'anello debole. Contromisure architetturali:

- **IPS (Intrusion Prevention System)**: strumenti come Fail2Ban (Linux) o script PowerShell (Windows) leggono i log monitorati dal SIEM e, superata una soglia (es. 5 tentativi falliti), dialogano con il firewall NGFW per un blocco dinamico dell'IP offensivo.
- **Zero Trust e MFA**: l'accesso ai server, anche interni, deve richiedere autenticazione multi-fattore e segmentazione via VLAN (microsegmentazione). Le null session vanno disabilitate tramite GPO su tutto il dominio.

6.2 Mitigazione delle Vulnerabilità Applicative

I 739 log di stato HTTP 500 impongono un intervento sull'esposizione del perimetro web: un **Web Application Firewall (WAF)**, operando a Livello 7, ispeziona il traffico e scarta i payload malformati prima che generino eccezioni sul web server o interroghino fraudolentemente il database.

6.3 Il Ciclo Operativo di Incident Response

Un evento come **EventCode 7045** (installazione di un servizio malevolo tramite psexec) attiva la procedura:

1. **Identificazione**: allarme generato dalle dashboard Splunk, arricchito con Threat Intelligence (IP reputation).
2. **Contenimento**: isolamento del nodo compromesso; egress filtering per impedire la comunicazione con eventuali C2 esterni o il movimento laterale verso i client.
3. **Investigazione ed eradicazione**: indagine forense via SPL per tracciare il perimetro dell'incidente, bonifica dei binari malevoli, reset delle credenziali compromesse (`djohnson`, `Administrator`).
4. **Recovery**: ripristino da backup isolati dalla rete (offline / immutable storage), per eludere eventuali minacce ransomware.

6.4 Mappatura MITRE ATT&CK e Difesa in Profondità

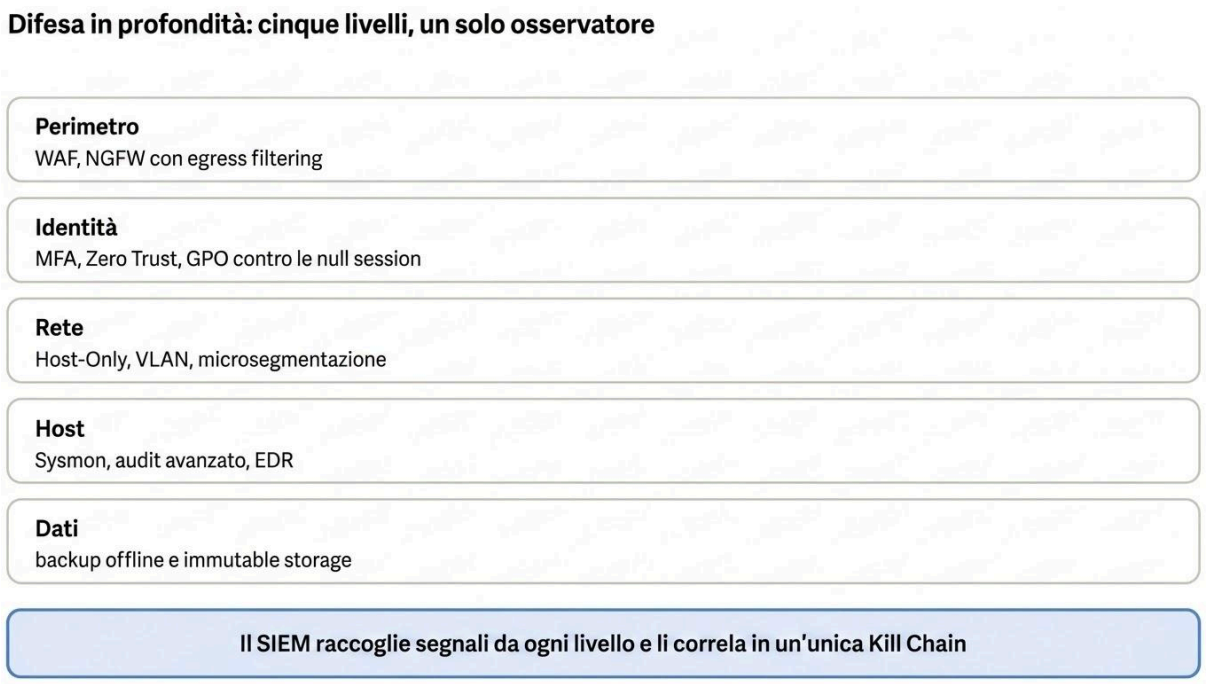
Per collegare ogni tecnica osservata a un linguaggio condiviso con il resto del settore, la tabella seguente mappa le tre categorie di attacco sulla matrice MITRE ATT&CK, insieme all'EventCode che ne costituisce la prova nel SIEM:

MAPPATURA MITRE ATT&CK E EVENTCODES

Categoria	Tecnica eseguita	Tattica MITRE	Technique ID	EventCode atteso
Ricognizione	enum4linux (null session SMB/RPC)	Discovery	T1087.002, T1018	4799, 4625
Credenziali	Hydra, brute-force su RDP	Credential Access	T1110.001	4625
Movimento laterale	Impacket psexec/smbexec	Lateral Movement, Execution	T1021.002, T1569.002	4624 (tipo 3), 7045, 5140

Questa mappatura permette di confrontare la copertura di detection del laboratorio con i framework usati in produzione (es. matrice di detection coverage di un SOC reale) e di individuare rapidamente eventuali blind spot residui.

La Kill Chain osservata in laboratorio è solo l'ultimo anello di una strategia di difesa che deve operare su più livelli contemporaneamente. Lo schema seguente sintetizza il modello Defense in Depth applicato in questo progetto:



7. Conclusioni Finali

Questo progetto dimostra l'importanza di passare da una rete priva di monitoraggio a un ambiente in cui i log vengono raccolti e analizzati centralmente. L'implementazione del dominio Active Directory e le simulazioni di attacco condotte con Kali Linux hanno confermato l'utilità pratica del SIEM nel tracciare le minacce.

Le difficoltà tecniche riscontrate nella configurazione dell'Universal Forwarder e nella lettura dei log storici sono state risolte in modo pragmatico, scrivendo query SPL su misura e utilizzando le espressioni regolari per estrarre le informazioni chiave.

In conclusione, sebbene l'approccio Defense in Depth non possa prevenire ogni possibile attacco, avere il SIEM come punto di controllo garantisce che le intrusioni non passino inosservate, permettendo di intervenire in modo tempestivo.

8. Limiti del Progetto

Il laboratorio, per sua natura, semplifica diverse condizioni reali. È utile dichiarare esplicitamente questi limiti, perché la consapevolezza dei confini di un test è parte della sua validità scientifica:

- **Scala**: un singolo DC, un solo client e un solo SIEM non riproducono la complessità di una rete aziendale con decine di sottoreti, trust tra domini e migliaia di endpoint.
- **Rumore di fondo**: in laboratorio ogni evento osservato è riconducibile all'attività pianificata; in produzione il traffico legittimo (migliaia di logon, query DNS, accessi a file) genera un rumore di fondo che complica la correlazione e richiede soglie e baseline più sofisticate.
- **Copertura parziale degli EventCode**: la detection qui descritta si fonda sui log nativi di Windows e su Sysmon; non è stata implementata una vera pipeline di threat intelligence (feed di IP reputation, integrazione con un EDR commerciale) che in un SOC reale arricchirebbe ogni alert.
- **Nessun test di evasione:** non sono stati simulati tentativi di elusione del logging stesso (es. disabilitazione di Sysmon, cancellazione dei log di sicurezza, uso di LOLBins per aggirare l'auditing) — un passo naturale per un secondo ciclo del progetto.
- **Separazione Red Team / Blue Team**: una scelta architetturale osservata in alcuni laboratori analoghi è quella di ospitare il SIEM sulla stessa macchina usata per sferrare gli attacchi. È una semplificazione comprensibile per ridurre il numero di VM, ma indebolisce il principio cardine dell'esercizio: se attaccante e difensore condividono lo stesso host, un'eventuale compromissione della macchina offensiva (o anche solo un errore di configurazione) espone direttamente il collettore dei log, vanificando l'assunto di base della Defense in Depth — che il punto di osservazione resti integro anche quando il perimetro viene violato. Nel nostro laboratorio, la separazione fisica tra Kali (192.168.56.101) e il server SIEM (Ubuntu + Splunk) garantisce che la capacità di detection non dipenda dall'integrità della macchina attaccante.

9. Lezioni Apprese

Al di là del risultato tecnico, il valore maggiore del progetto è metodologico:

1. **La visibilità non è gratuita**: un SIEM vede solo ciò che i sistemi sono configurati per registrare. L'auditing avanzato e Sysmon non sono un dettaglio opzionale, ma il prerequisito di ogni detection — un punto spesso sottovalutato in laboratorio quanto in produzione.
2. **Un blocco applicativo non è una detection**: l'hardening di Windows Server ha impedito l'enumerazione anonima, ma solo l'analisi dei log ha reso visibile il tentativo. Bloccare un attacco e accorgersene sono due capacità distinte, ed è la seconda a permettere la risposta e il miglioramento continuo.
3. **Il rumore sistemistico è parte del lavoro**: la diagnosi del guasto alla pipeline (SPL confuso con INI) ha richiesto più tempo della configurazione di un singolo attacco — una proporzione realistica rispetto al lavoro quotidiano di un analista SOC o di un ingegnere SIEM.
4. **Un Event ID da solo dice poco**: la forza della detection nasce dalla correlazione (sorgente, account, orario, volume), non dal singolo evento isolato — da cui l'importanza di annotare con precisione comando ed esito di ogni azione offensiva.

Appendice A — Glossario degli Event ID Principali

Event ID	Nome	Significato operativo
4624	An account was successfully logged on	Accesso riuscito; il Logon Type (es. 3 = rete) distingue un accesso interattivo da uno via SMB/RPC
4625	An account failed to log on	Tentativo di accesso fallito; in volume elevato è la firma di un attacco a dizionario o brute-force
4768	Richiesto un TGT Kerberos	Se la pre-autenticazione è disabilitata, rivela un tentativo di AS-REP Roasting
4769	Richiesto un Service Ticket Kerberos	La cifratura RC4 (0x17) invece di AES è l'indicatore classico di Kerberoasting
4799	Enumerata l'appartenenza a un gruppo locale	Frequente durante la ricognizione anonima via SMB/RPC
5140	Accesso a un oggetto di condivisione di rete	Utile per rilevare l'uso delle share amministrative (`ADMIN$` , `IPC$`)
7045	Installato un nuovo servizio	Firma quasi univoca degli strumenti PsExec-like

Appendice B — Comandi di Riferimento

Fase	Comando
Ricognizione	`enum4linux -a 192.168.56.105`
Credenziali (brute-force RDP)	`hydra -l Administrator -P pass.txt rdp://192.168.56.105 -V -f`
Movimento laterale	`impacket-psexec 'Administrator:Password123!@192.168.56.105' ipconfig`
Ricerca SIEM — tentativi falliti	`EventCode=4625`
Ricerca SIEM — movimento laterale	`host=DC-SERVER EventCode=7045`
Ricerca SIEM — Top Offenders	pipeline regex completa, vedi §5.4